Implementing Security Features and Governance / Administration Practices in Zoho Creator

Project: Insurance Claim Management System

Experiment No: 12
Name: Adishwar Seelan SK
Roll No: 241401004
Department: CSBS

1. Aim

To plan and apply security features and governance and administration practices in the Insurance Claim Management System built in Zoho Creator covering sign-in security, user access, data permissions, safe scripting and integrations, controlled changes and auditing so that claim data is protected and the application is managed in an orderly way.

The application stores personal and financial details such as claimant identity, contact information, policy numbers, claim amounts and incident descriptions, so access control and accountability are essential.

2. Procedure

Step 1: Identify what needs protection
The Claim Request Form, Claim Request Report and related data were reviewed, and the sensitive data was listed: claimant identity, contact details, policy number, claim amount, incident description and supporting documents.

Step 2: Plan account security
Sign-in protection was planned for all users: strong passwords, two-factor sign-in and single sign-on where the organisation uses it (Section 3.1).

Step 3: Design roles and permissions
Claims Administrator, Claims Reviewer, Claims Officer and Claimant roles were defined, and a permission matrix was prepared following the principle of least privilege (Section 3.2).

Step 4: Define the access flow
The checks made when a user opens the application were drawn as a decision flow (Section 3.3).

Step 5: Plan safe scripting and integrations
Safe Deluge practices were drafted, such as validating input and keeping connections limited to administrators, based on the validation, connection and workflow rules from Experiments 1, 6 and 7 (Section 3.4).

Step 6: Plan change governance and auditing
Controlled changes through development, stage and production environments, audit review and periodic access reviews were planned (Section 3.5).

Step 7: Prepare the admin checklist
Threats and matching controls were tabulated, and an administration checklist was prepared for regular use (Sections 3.6 and 3.7).

Note: the settings are described as a planned configuration. No screenshots of the settings were captured for this record, so it does not claim that every option was turned on. Feature names and availability depend on the Zoho Creator plan and version and should be confirmed in the current documentation.

3. Output

3.1 Layered security and governance model

Security is arranged in five layers: account sign-in, application access, data access, logic and integrations, and governance with audit. A failure in one layer is caught by the next, which is the idea of defence in depth.

- Governance and audit: Controlled changes, audit trail, periodic reviews
- Logic and integrations: Validated scripts, administrator-only connections
- Data access: Form, report, field and record permissions
- Application access: Roles and profiles: Claims Administrator, Reviewer, Officer
- Account sign-in: Strong passwords, two-factor sign-in, single sign-on

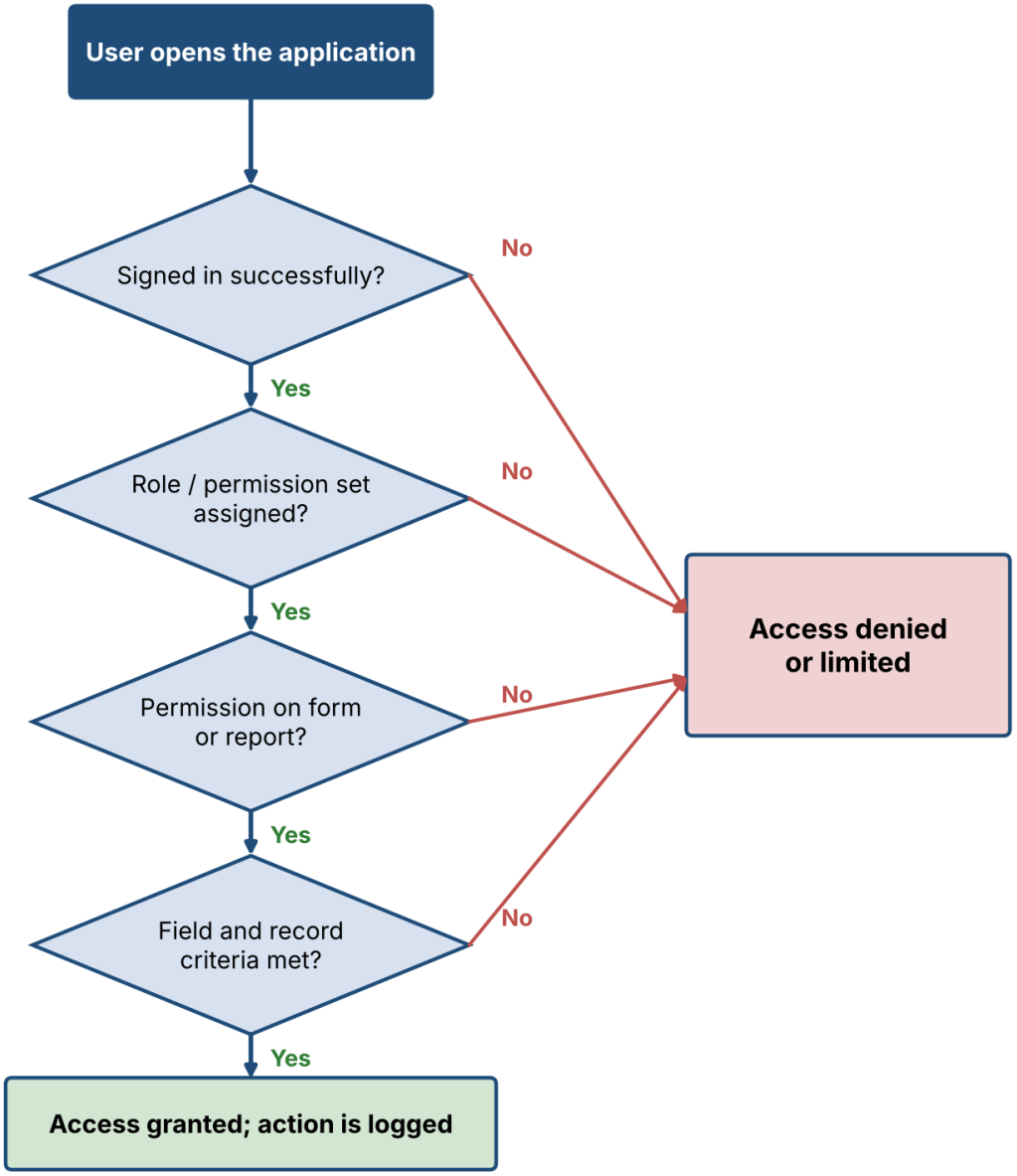
3.2 Proposed permission matrix

Each user type receives only the access needed for the job (least privilege). The matrix is a proposed design for the claim management system.

Form/report	Claims Administrator	Claims Reviewer	Claims Officer	Claimant
Insurance Claim Request Form	View, edit, delete	View, update review fields	Create, view, edit	Create and view …
Claim Request Report	Full access	View assigned claims	View, edit permitted …	View own claims
Claim decision (approve / reject)	Full access	Update decision	No access	No access
Sensitive fields (claim amount, documents)	View, edit	View	Create and edit	Own entry only
Reports and exports	All reports, export	Own reports	Daily claim list only	No access
Users, connections, environments	Manage	No access	No access	No access

3.3 Access control decision flow

When a user tries to open the application, the system checks sign-in, then the assigned profile or role, then permission on the form or report, and finally field and record criteria. Failing any check denies or limits access, and granted actions are logged.



Conceptual diagram

3.4 Secure scripting and connection practices (illustrative)

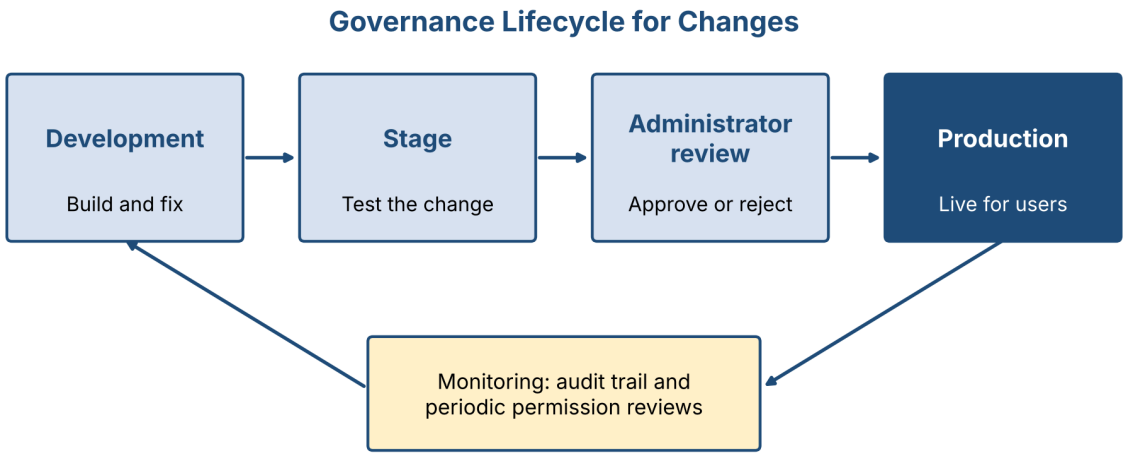
```
// On validate of the Insurance Claim Request Form
if(input.Claim_amount_requested <= 0)
{
    alert "Claim amount must be greater than zero.";
    cancel submit;
}
if(input.Date_of_incident > zoho.currentdate)
{
    alert "Incident date cannot be in the future.";
    cancel submit;
}

// Connection: use the stored link name, never a key written in the script
response = zoho.calendar.createEvent(calendar_id, event,
"insurance_claim_calendar");
```

Input is validated on the server side of the form so wrong or missing data is rejected. Credentials stay in the connection, which is set to administrators only (as in Experiment 7), and the calendar ID should be stored in a setting instead of being written inside the script. The code is illustrative; field and connection link names must match those in the application.

3.5 Governance lifecycle for changes

Changes move from the development environment to the stage environment for testing, then to an administrator review, and only then to the production environment. Monitoring through the audit trail and periodic permission reviews feed improvements back into development.



Feedback from monitoring returns to development (conceptual diagram)

Figure 3: Governance Lifecycle for Changes (Conceptual Diagram)

3.6 Threats and matching controls

Threat	Example in this application	Control
Unauthorised access	A stranger or former staff member opens claim data.	Two-factor sign-in, remove users promptly, profile-based access.
Excess privilege	A claims officer can delete or export all records.	Least privilege, separate permissions for delete and export.
Data leakage	Reports or forms shared publicly by mistake.	Review sharing settings, avoid public links for sensitive reports.
Insecure scripts	Missing validation or keys written inside Deluge code.	Validation on submit, connections instead of keys, code review.
Uncontrolled change	A live fix breaks claim submission or permissions.	Development, stage and production environments with approval.
No traceability	Nobody can tell who changed a claim record.	Audit trail review and periodic log checks.

3.7 Administration checklist

Area	Administration practice	How often
Users	Add users with the correct role; remove leavers the same day.	On every change
Permissions	Review roles and exports against the permission matrix.	Every quarter
Sign-in	Confirm two-factor sign-in or single sign-on is enforced.	Every quarter

Area	Administration practice	How often
Connections	Check that connections are administrator-only and used only by needed apps.	Every quarter
Changes	Publish only after testing in the stage environment.	Every release
Audit	Look through the audit trail and usage metrics for unusual activity.	Monthly
Backup and recovery	Keep a recent backup and test that data can be restored.	As planned

4. Final Result

A layered security and governance plan was prepared for the Insurance Claim Management System, covering sign-in protection, role-based access with a least-privilege permission matrix, an access-control decision flow, secure scripting and connection practices, controlled changes through environments, and regular auditing.

Threats such as unauthorised access, excess privilege, data leakage, insecure scripts, uncontrolled change and lack of traceability were matched with controls, and an administration checklist was drawn up for regular use.

The exercise met its objective of designing security and governance for the application. The settings were not captured as screenshots, so the record presents them as a planned configuration to be confirmed in the live application.